

Unlokt — GDPR & procurement pack

For: the Gender Capital Lab™ Sprint platform (`ifc-sprint-platform.vercel.app`). Prepared 2026-06-13.

This folder holds the documents a financial-services client's privacy and procurement teams will ask for before they let the platform touch their data.

Not legal advice — drafts for review. These are professional starting points written from the platform's actual architecture. A DPA is a binding contract and a DPIA is a regulated assessment. **Have a privacy lawyer or a DPO review everything in this folder before you sign or send it.** Where a fact could not be confirmed on an official source, it is marked **△ CONFIRM** — close those before anything is signed.

What's here

File	What it is	Audience
<code>01_data-flow-and-residency.md</code>	The honest map: what personal data the platform holds, and exactly where it goes (EU vs US).	Internal + client privacy team
<code>02_subprocessor-list.md</code>	The three subprocessors (Anthropic, Vercel, Turso), their role, location, and DPA/transfer posture.	Client procurement
<code>03_DPA-template.md</code>	Verwerkersovereenkomst (Data Processing Agreement) draft — Unlokt as processor, the client as controller, with annexes.	Lawyers, both sides
<code>04_retention-and-deletion.md</code>	How long data is kept and how it is erased (the platform has a working delete + backup capability).	Client privacy team
<code>05_security-measures-TOMs.md</code>	Technical & organisational measures — honest, including current gaps.	Client security team
<code>06_DPIA-input.md</code>	Input for the client's Data Protection Impact Assessment (they run it; we supply the processing facts and risks).	Client DPO
<code>07_security-questionnaire-prefill.md</code>	Pre-filled answers to the standard vendor security questionnaire.	Client procurement
<code>08_privacy-notices-NL.md</code>	Ready-to-use Dutch consent & notice text for the crew intake and the test panel.	Goes into the product
<code>09_open-items-and-decisions.md</code>	The risk register: what must be confirmed, obtained, or decided before the first real client sprint.	Founders

The one-paragraph version (for a first procurement conversation)

Data at rest lives in the EU (Turso, Ireland). Application compute runs in the EU (Vercel, Frankfurt). The only data leaving the EU is what is sent to the Claude AI for analysis — processed in the US by Anthropic under Standard Contractual Clauses, **never used to train models**, and auto-deleted within 30 days. Personal data is minimised, access is controlled, and there is a working data-erasure process. Full DPA, subprocessor list and security measures available on request.

Read `09_open-items-and-decisions.md` before you say any of that out loud — a few claims still need a manual confirmation.

Data flow & residency

The honest map of what personal data the platform processes and where it goes. Everything else in this pack is downstream of this document — keep it accurate.

Draft for review, not legal advice. See `README.md` .

Roles

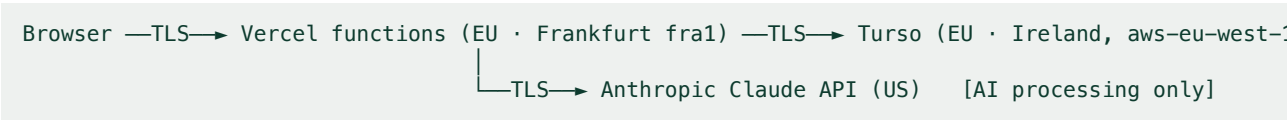
For a sprint engagement, the **client** (e.g. BeFrank) is the **controller** (verwerkingsverantwoordelijke) — it decides the purpose. **Unlockt** is the **processor** (verwerker), acting on the client's documented instructions. Anthropic, Vercel and Turso are **sub-processors** (see `02_subprocessor-list.md`).

What personal data the platform holds

Data subject	Personal data	Sensitivity
Client crew (client employees doing the intake)	Name, role; free-text pre-work answer; AI-interview transcript (their opinions about their employer/colleagues); self-assessment answers (numeric)	Free-text answers can be career-sensitive in an employment context. Not Art. 9 special-category data.
Uploaded documents	Whatever the crew uploads (research, decks, board reports) — may contain third-party personal data and confidential business data	Variable. Clients are instructed not to upload special-category data (health, etc.).
Test panel (consumers from the target group)	First name + age band (e.g. "Sanne, 34"); verbal reactions/quotes; 1–5 scores	Panelists may volunteer personal financial circumstances. Minimised by design: first name + age only, no full identification.

The market-research brief is about the company, not data subjects, and contains only public-source information — negligible personal data.

Where the data goes



Layer	Provider	Location	What it handles
App compute	Vercel	EU — Frankfurt (fra1)	Runs the application; transient processing only, no primary data store
Database (at rest)	Turso	EU — Ireland (aws-eu-west-1)	The system of record: all sprint data
AI processing	Anthropic (Claude API)	US	Receives the text sent to AI features; see below

The US transfer (Anthropic) — the one flow to disclose clearly

The AI features send text to Anthropic's first-party Claude API, which processes and stores at-rest **in the United States**. The first-party API has **no EU data-residency option** (EU processing for Claude exists only via AWS Bedrock or Google Vertex, which this platform does not currently use).

What is sent to Anthropic:

- **AI interview** → the crew member's free-text answers.
- **Document analysis** → the full text of each uploaded document.
- **Readout** → the panel's quotes and scores.
- **The research brief**, pre-read, canvas suggestions, prototype build and

Ask-the-library send company/derived content — minimal to no data-subject personal data.)

Transfer safeguards:

- **Standard Contractual Clauses** in Anthropic's DPA are the transfer mechanism. [△] **CONFIRM** the exact SCC module/version against the live DPA.
- **Not training**. Anthropic does not use commercial/API data to train models.
- **Retention: 30 days**. Anthropic auto-deletes API inputs/outputs within 30 days. **Note**: the current model (`claude-opus-4-8`) mandates 30-day retention and **cannot** run under Zero-Data-Retention — so a true "zero retention" claim is **not** available on this model today. Data tied to a flagged policy violation may be kept up to 2 years.
- [△] **CONFIRM** Anthropic's EU-US Data Privacy Framework status at dataprivacyframework.gov/list (sources conflict — do not state it unconfirmed).

Mitigations already in place

- **App** compute moved from the US default to **EU (Frankfurt)** — `vercel.json` pins `fra1` .
- **Database** is in the **EU (Ireland)** by region choice.
- **Personal data** is **minimised** before it reaches the AI (panelists are first-name + age; the assessment sends numbers, not identities).

The EU-residency upgrade path (a decision, not a fix)

If a client requires AI processing to stay in the EU, the AI layer can be moved to **Claude on AWS Bedrock (EU region)** or **Google Vertex AI** (`region:"eu"`). That is an architecture change (different SDK/auth, model-id changes, model-availability check) — scope it only if a client makes it a condition. Documented here so the option is on the table, not buried.

Legal basis (controller to confirm)

The controller (client) sets the legal basis. Typically: the engagement contract / legitimate interest for the crew, and **explicit consent** for the consumer test panel (with incentive disclosure — see `08_privacy-notices-NL.md`).

Sub-processor list

The third parties that process personal data on Unlockt's behalf to deliver the sprint platform. Maintain this list; notify clients of changes per the DPA.

Draft for review. Facts below were researched 2026-06-13 from official vendor sources. Items marked △ **CONFIRM** rest on search-level corroboration and must be verified by opening the cited page before this list is relied on in a contract.

Sub-processor	Role	Processing location	Data it touches
Anthropic, PBC	AI processing (Claude API)	US	Interview text, document text, panel feedback (see 01_...)
Vercel Inc.	Application hosting & serverless compute	EU — Frankfurt (fra1) (pinned)	All request/response data in transit; no primary store
Turso (ChiselStrike, Inc.)	Database (libSQL)	EU — Ireland (aws-eu-west-1)	The system of record: all sprint data at rest

Underlying infrastructure for all three is **Amazon Web Services** (Vercel and Turso run on AWS; Anthropic runs on AWS and Google Cloud).

Anthropic (Claude API)

- Role:** processor for commercial/API customers.
- DPA:** offered, auto-incorporated into the Commercial Terms (clickthrough). Accept/keep on file. △ **CONFIRM** at privacy.claude.com.
- Transfers:** DPA includes EU **SCCs** (+ UK addendum). △ **CONFIRM** exact module/version against the live DPA.
- DPF:** △ **CONFIRM** — sources conflict; check dataprivacyframework.gov/list before stating.
- Location:** US only on the first-party API; **no EU residency** option (EU only via Bedrock/Vertex — not used here).
- Retention:** inputs/outputs auto-deleted within **30 days**; **30-day retention is mandatory on** claude-opus-4-8 (no ZDR on this model); up to 2 years if a request is flagged for policy violation.
- Training:** **does not train on commercial/API data.** ✓
- Certifications:** SOC 2 Type II, ISO 27001:2022, ISO 42001 referenced. △ **CONFIRM** current set at trust.anthropic.com.
- Sub-processors:** trust.anthropic.com/subprocessors (updated 2026-03-26). △ **CONFIRM** / pull live.
- Encryption:** TLS in transit (HTTPS to api.anthropic.com); at-rest statement △ **CONFIRM** at trust.anthropic.com.

Vercel

- Role:** processor (hosting/compute).
- DPA:** published at vercel.com/legal/dpa (Pro/Enterprise).
- Transfers:** EU **SCCs** + UK addendum; **certified under the EU-US Data Privacy Framework.** ✓

Location: default US, but **region-pinned to EU (Frankfurt fra1)** for this project via `vercel.json` .

Note: Vercel backups are globally replicated; standard plans do not guarantee EU-only persistence — Enterprise "Secure Compute" if a client requires it.

Retention: backups every 2h, retained 30 days, deleted with the instance. Application data retention is governed by our own config + the DPA.

Certifications: SOC 2 Type 2, ISO 27001:2022, PCI DSS v4.0, HIPAA (Enterprise BAA), TISAX AL2.

✓

Encryption: **AES-256 at rest, TLS 1.3 in transit.** ✓

Sub-processors: security.vercel.com (Trust Center). [△ CONFIRM](#) / pull live.

Turso (libSQL database)

Role: processor (database).

DPA: offered to EU customers on Scaler/Pro/Enterprise, **requested via the trust portal** (not clickthrough) — **must be actively obtained and kept on file before go-live.** trust.turso.tech.

Transfers: [△ CONFIRM](#) — SCCs/DPF **not verified**. Turso is US-incorporated and runs the control plane; confirm the DPA's transfer clauses even though data-at-rest is in Ireland.

Location: data pinned to **EEA — Ireland (aws-eu-west-1)**. ✓ [△ CONFIRM](#) whether control-plane/account metadata also stays in-region.

Retention: database content persists until deleted (it's our database); deleting a database deletes its backups. No separate default TTL confirmed.

Certifications: **SOC 2 Type II completed** (recent — confirm letter date at trust.turso.tech); HIPAA/BAA on Pro. ISO 27001 [△ CONFIRM](#) .

Encryption: at rest by default (volume-level) plus optional native page-level encryption (AEGIS-256 / AES-GCM, keys in memory only, optional BYOK); TLS in transit (exact version [△ CONFIRM](#)). ✓

Before go-live with a real client

- 1 Get all **three DPAs on file** (Turso's must be actively requested).
- 2 **Verify Anthropic's DPF status** (dataprivacyframework.gov/list) and the SCC versions in all three DPAs.
- 3 Pull each provider's **live sub-processor list** and diff against this table.
- 4 Confirm Turso's **transfer mechanism** (SCCs) explicitly.

Tracked in `09_open-items-and-decisions.md` .

Verwerkersovereenkomst (Data Processing Agreement) — template

NOT A SIGNED CONTRACT. NOT LEGAL ADVICE. This is a drafting starting point built to GDPR Art. 28. A processor agreement is a binding legal instrument — **a privacy lawyer must review and adapt it before either party signs.** Brackets [...] are fields to complete. Many clients will prefer their own DPA template; this exists so you can respond fast and negotiate from a position of readiness, not from a blank page.

Verwerkersovereenkomst between:

[Client legal name], the **Controller** ("Verwerkingsverantwoordelijke"); and
[Unlockt legal entity name, KvK no.], the **Processor** ("Verwerker").

This agreement supplements the services agreement dated [date] (the "Main Agreement") and governs the Processor's processing of personal data on the Controller's behalf in delivering the Gender Capital Lab™ Sprint platform.

1. Scope & instructions

1.1 The Processor processes personal data only on the Controller's documented instructions, including the processing set out in **Annex 1**, unless required otherwise by EU or Member State law (in which case it informs the Controller first, unless the law prohibits this). 1.2 The Processor informs the Controller if, in its opinion, an instruction infringes the GDPR.

2. Confidentiality

The Processor ensures persons authorised to process the data are bound by confidentiality.

3. Security

The Processor implements appropriate technical and organisational measures per GDPR Art. 32, as set out in **Annex 2**.

4. Sub-processors

4.1 The Controller gives general authorisation for the sub-processors listed in **Annex 3**. 4.2 The Processor informs the Controller of intended additions or replacements, giving the Controller [14] days to object on reasonable data-protection grounds. 4.3 The Processor imposes the same data-protection obligations on each sub-processor by contract and remains liable for their performance.

5. Data-subject rights

The Processor assists the Controller with appropriate technical and organisational measures, insofar as possible, to respond to data-subject requests (Art. 12–23), and forwards any request it receives directly to the Controller without undue delay.

6. Assistance

The Processor assists the Controller in ensuring compliance with Art. 32–36 (security, breach notification, DPIA, prior consultation), taking into account the nature of processing and the information available to it.

7. Personal-data breaches

The Processor notifies the Controller without undue delay and at the latest within **[24 / 48] hours** of becoming aware of a personal-data breach, with the information the Controller needs to meet its Art. 33/34 obligations.

8. Return & deletion

On termination, at the Controller's choice, the Processor deletes or returns all personal data and deletes existing copies, unless EU/Member-State law requires storage. The Processor's deletion process and timelines are described in `04_retention-and-deletion.md`.

9. Audits & information

The Processor makes available to the Controller information necessary to demonstrate compliance with this agreement and Art. 28, and allows for and contributes to audits, including inspections, conducted by the Controller or an auditor it mandates ([reasonable notice; once per year unless an incident]).

10. International transfers

10.1 The Processor and its sub-processors transfer personal data outside the EEA only with appropriate safeguards (Art. 46), principally **Standard Contractual Clauses**. 10.2 The Controller acknowledges that AI processing is performed by **Anthropic in the United States** under SCCs, as described in `01_data-flow-and-residency.md` and `02_subprocessor-list.md`, with no use of data for model training and a 30-day deletion window.

11. Liability, term, governing law

Liability follows the Main Agreement. This agreement runs for the term of the Main Agreement. Governed by **[Dutch] law**; disputes before the courts of **[Amsterdam]**.

Signed: Controller _____ Processor _____ Date _____

Annex 1 — Processing details

Subject matter: delivery of the Gender Capital Lab™ Sprint platform.

Duration: the term of the Main Agreement.

Nature & purpose: intake, diagnostic analysis, AI-assisted research and concept/prototype generation, and capture of test-panel feedback.

Types of personal data: names and roles of client crew; their free-text

intake and interview answers; self-assessment responses; the contents of documents the crew uploads; test-panel participants' first name, age band, scores and verbal feedback.

Categories of data subjects: the client's employees (crew); persons referenced in uploaded documents; consumer test-panel participants.

Special categories: none intended. Controller instructs crew not to upload special-category data.

Annex 2 — Technical & organisational measures

See `05_security-measures-TOMs.md` (incorporated by reference).

Annex 3 — Sub-processors

See `02_subprocessor-list.md` (incorporated by reference): Anthropic (US, AI), Vercel (EU-Frankfurt, hosting), Turso (EU-Ireland, database).

Retention & deletion

Draft for review. See README.md .

Principle

Sprint data is kept only as long as needed for the engagement and the agreed follow-up, then erased. The platform has working **backup** and **erasure** capabilities (below), so this policy describes real mechanisms, not intentions.

Retention schedule (controller to set the exact periods)

Data	Default retention	Trigger to delete
Sprint records (scores, concepts, prototypes, readout)	Engagement + [12] months for follow-up advisory	End of retention period, or on controller request
AI-interview transcripts & uploaded documents	Engagement + [3] months	End of period, or on request
Test-panel feedback (first name, age, quotes, scores)	[3] months after the sprint	End of period
Backups (our snapshots)	[90] days , rolling	Auto-expire

These are starting defaults — the **controller decides** the periods in the DPA.

How erasure actually works

1 **Our database (Turso, EU).** `npm run delete-sprint <sprintId> --apply`

permanently deletes the sprint and every attached row (participants, assessments, scores, documents, concepts, feedback) across all tables. Run a dry-run first (omit `--apply`) to see exactly what will go.

1 **Our backups.** Snapshots are local JSON files (`npm run backup`); purge the relevant file(s) when honouring an erasure request, or let them roll off the 90-day window.

1 **Sub-processor copies — age out automatically:**

Anthropic: API inputs/outputs auto-deleted within **30 days** (no action needed; not retrievable by us in the meantime).

Vercel: backups roll off within **30 days**.

Turso: deleting the data above removes it from the live database; deleting a database also deletes its backups.

So a data-subject erasure request is satisfied by: delete from our DB now → purge the relevant backup → confirm sub-processor copies age out within 30 days. **Maximum time to full erasure across all systems: 30 days** (bounded by the Anthropic/Vercel windows), immediate in our own store.

Data-subject requests

Forward any request received directly to the **controller** (it owns the relationship and the legal basis). On the controller's instruction, action it using the mechanisms above and confirm completion in writing.

Caveat on `claude-opus-4-8`

The current AI model mandates a 30-day Anthropic-side retention and cannot run zero-retention (see `01_...`). So "immediate and total erasure everywhere" is not truthful while data is within that 30-day window — state the **30-day bound** honestly. If a client requires faster guaranteed erasure at the AI layer, that is part of the EU-residency / model decision in `09_open-items-and-decisions.md` .

Technical & organisational measures (TOMs)

GDPR Art. 32. Annex 2 to the DPA. **Honest** — gaps are listed with remediation, because a procurement team trusts a named gap + a plan more than a glossy claim.

Draft for review. See README.md .

In place

Encryption

- In transit: HTTPS/TLS on every hop (browser↔Vercel, Vercel↔Turso, Vercel↔Anthropic).
- At rest: Turso volume-level encryption (+ optional page-level AES/AEGIS-256, keys in memory only); Vercel AES-256.

Data residency

- Database at rest: EU — Ireland (aws-eu-west-1).
- App compute: EU — Frankfurt (fra1), pinned in vercel.json .

Access control

- Facilitator area (dashboards, research, AI endpoints) behind HTTP basic auth.
- Client pages reachable only via an unguessable per-sprint token (no listing, not indexed — robots: noindex).
- Production secrets in environment variables (Vercel/ .env*), never in code or git; verified no secret is committed.

AI data handling

- Anthropic does not train on the data. Inputs/outputs auto-deleted within 30 days. Data minimised before it reaches the AI (panelists = first name + age; assessment sends numbers).

Data lifecycle

- Working erasure (npm run delete-sprint ... --apply) and backup (npm run backup) capabilities.

Software

- Managed platform (Vercel) — OS/runtime patching handled by the provider. No customer-managed servers.

Gaps & remediation (honest)

Gap	Risk	Remediation	Priority
Shared facilitator password (one basic-auth login for the whole team)	No individual accountability; no record of who accessed what; can't revoke one person	Move to per-user accounts with individual credentials	High — before first real client
No access audit log	Can't show who viewed a sprint's data when	Add request/access logging on facilitator routes	High

Gap	Risk	Remediation	Priority
No MFA on the facilitator login	Weaker against credential compromise	Add MFA with per-user accounts	Medium
Client links are bearer tokens	Anyone with the link can open that sprint's intake	By design (frictionless client access); mitigate with link expiry + per-sprint rotation	Medium
Manual backups	A missed backup before an incident	Schedule <code>npm run backup</code> (cron / Vercel Cron)	Medium
No formal incident-response runbook	Slower, inconsistent breach handling	Write a one-page IR runbook (who, what, the 24/48h notify clock)	Medium
No penetration test	Unknown unknowns	Commission a light pen-test before scaling beyond the pilot	Low→Medium

Organisational

Small team; access on a need-to-know basis. Confidentiality is part of the founders' / contractors' engagement.

Sub-processors are vetted (see `02_subprocessor-list.md`) and bound by their own DPAs.

This pack is the documented baseline; review it each time the architecture changes.

DPIA input

A Data Protection Impact Assessment is the **controller's** (client's) duty. The client's DPO runs it; this document gives them the processing facts and a candid risk analysis so they can complete it quickly.

Draft for review. See README.md .

Is a DPIA required?

Likely **recommended** (and the client's DPO may treat it as required) because the processing combines: employees' free-text opinions, consumer participants, and **AI/innovative technology**. It is **not** automated decision-making with legal or similarly significant effect on individuals (Art. 22) — the AI designs product concepts; it does not make decisions about people. Note this clearly; it materially lowers the risk profile.

Processing description

See 01_data-flow-and-residency.md . In short: intake (names, roles, free-text answers, uploaded documents), AI-assisted analysis and concept generation, and a consumer test panel (first name, age, feedback). Controller: client. Processor: Unlockt. Sub-processors: Anthropic (US, AI), Vercel (EU), Turso (EU).

Necessity & proportionality

Purpose: improve the client's products/propositions for underserved (women) customers — a legitimate commercial purpose.

Data minimisation: panelists identified by first name + age only; assessment captured as numbers; AI receives only what each feature needs.

The US transfer is the minimum necessary to use the AI capability, covered by SCCs and no-training; an EU-residency path exists if required (01_...).

Risks to data subjects & mitigations

Risk	Who	Mitigation
Career-sensitive opinions exposed (crew criticising employer)	Crew	Access control; the morning "mirror" presents quotes anonymised ; short retention; data minimisation
Uploaded document contains third-party / sensitive data	Third parties	Instruction not to upload special-category data; short retention; access control
Consumer reveals personal financial circumstances	Panel	Explicit consent; first-name+age only; anonymised use of quotes; short retention
Transfer to US (Anthropic)	All AI-touched data	SCCs; no training; 30-day deletion; minimisation before sending

Risk	Who	Mitigation
AI inaccuracy / hallucination influencing decisions	Client	Human-in-the-loop: the facilitator reviews AI output (findings, research) before the room sees it; AI output is advisory, never auto-actioned
Unauthorised facilitator access	All	Auth on facilitator routes; gap: shared password / no audit log — see 05_... remediation

Residual risk

With the mitigations above, residual risk is **assessed as low-to-medium**, driven mainly by (a) the US transfer (managed by SCCs + no-training + 30-day deletion) and (b) the access-control gaps in 05_... (remediable before the first real client). The controller's DPO makes the final determination.

Consultation

If the DPO concludes residual risk remains high after mitigation, prior consultation with the Autoriteit Persoonsgegevens (Art. 36) may be warranted — the no-Art.-22 and human-in-the-loop points should weigh against that.

Security questionnaire — pre-filled answers

Drop-in answers to the questions a financial-services vendor questionnaire usually asks. Keep answers honest; where there's a gap, say so + the plan.

Draft for review. See `README.md` .

Question	Answer
What personal data do you process, and for whom?	See <code>01_data-flow-and-residency.md</code> . We are processor; the client is controller.
Where is data stored / processed?	At rest: EU (Turso, Ireland). Compute: EU (Vercel, Frankfurt). AI processing: US (Anthropic) under SCCs, no training, 30-day deletion.
Is data encrypted in transit and at rest?	Yes. TLS on every connection; AES-256 (Vercel) / volume + optional page-level AES/AEGIS-256 (Turso) at rest.
Do you offer a DPA?	Yes — see <code>03_DPA-template.md</code> (or we sign the client's).
Do your sub-processors offer DPAs / SCCs?	Yes (Anthropic, Vercel); Turso DPA is request-based and obtained per engagement. See <code>02_subprocessor-list.md</code> .
International transfers — what safeguards?	SCCs. Vercel is DPF-certified. Anthropic DPF status to be confirmed per engagement.
Is our data used to train AI models?	No. Anthropic does not train on commercial/API data.
What is your data-retention policy?	See <code>04_retention-and-deletion.md</code> . AI-side: 30-day auto-deletion (mandatory on the current model).
Can you delete our data on request (right to erasure)?	Yes — working erasure process; immediate in our store, ≤30 days across all systems.
Access control?	Auth on all facilitator routes; client access via per-sprint tokens. Gap: shared team password / no per-user accounts yet — remediation planned before first client (<code>05_...</code>).
MFA?	Not yet — planned with per-user accounts.
Audit logging?	Not yet — planned (<code>05_...</code>).
Backups?	Yes (<code>npm run backup</code>); scheduling planned.
Certifications (yours)?	Unloct holds none yet (early-stage). Sub-processors: Vercel & Turso SOC 2 Type II + ISO 27001; Anthropic SOC 2 II / ISO 27001 / ISO 42001 (confirm current).
Incident response / breach notification?	We notify the controller within [24/48]h of awareness (DPA §7). Formal IR runbook: planned (<code>05_...</code>).
Penetration testing?	Not yet for this platform; planned before scaling past the pilot.
Automated decision-making affecting individuals (Art. 22)?	No. AI output is advisory and human-reviewed; it designs product concepts, not decisions about people.
Sub-contractors / where is the team?	Small EU-based team; access on need-to-know.

Honesty note: several "not yet" answers above are early-stage gaps with named remediation in 05_security-measures-TOMs.md . Presenting them with a plan is the right move for a pilot — do not paper over them.

Privacy notices & consent — Dutch (drop-in)

Ready-to-use Dutch text for the product. Two audiences: the **client crew** (intake) and the **test panel** (consumers). The controller (client) confirms the legal basis and is named in [...] .

Draft for review by the controller's DPO before it goes live.

A. Crew intake — privacy notice (Art. 13)

Place on /s/<token>/intake , above the form. The legal basis for employees is typically the engagement / legitimate interest, set by the employer-controller.

Even over je privacy

Je vult deze intake in voor de Gender Capital Lab Sprint van **[Klant]**. Wat je hier invult — je naam, je rol, je antwoorden en de documenten die je uploadt — gebruiken we alleen om de sprint voor te bereiden.

Wie is verantwoordelijk? [Klant] is verantwoordelijk voor je gegevens;

Unlocks verwerkt ze in opdracht van [Klant].

Wat doen we ermee? We analyseren je antwoorden en documenten — deels met

AI (Claude van Anthropic) — om de bevindingen voor de sprintdag te maken. Citaten gebruiken we in de ochtendpresentatie **anoniem**.

Waar gaat het heen? Je gegevens staan opgeslagen in de EU (Ierland). Voor

de AI-analyse gaat tekst naar de VS (Anthropic), onder wettelijke waarborgen (SCC's); deze wordt **niet gebruikt om AI te trainen** en binnen 30 dagen verwijderd.

Hoe lang? We bewaren je antwoorden niet langer dan nodig voor de sprint

en de afgesproken opvolging (zie de afspraken met [Klant]).

Geen bijzondere gegevens. Upload geen documenten met bijzondere

persoonsgegevens (bijv. gezondheid).

Je rechten. Inzage, correctie of verwijdering? Neem contact op met

[contact bij Klant / functionaris gegevensbescherming].

A short acknowledgement line by the submit button:

Door verder te gaan ga je akkoord met deze verwerking zoals hierboven beschreven.

B. Test panel — consent form (explicit opt-in)

For the evening panel. Consumers → **explicit consent** is the cleanest basis. Show before the session; capture a tick / signature. Keep a record.

Toestemming voor deelname aan het testpanel

Bedankt dat je vanavond meedenkt met **[Klant]**. Voordat we beginnen, even dit:

Wat we vastleggen: je voornaam en leeftijd, je reacties op de ideeën, en een aantal scores. Geen achternaam, geen contactgegevens in de testresultaten.

Waarvoor: om de concepten te verbeteren. **[Klant]** is verantwoordelijk voor je gegevens; Unlocked verwerkt ze in opdracht.

Citaten: we gebruiken wat je zegt **anoniem** in de terugkoppeling.

Waar gaat het heen: opgeslagen in de EU; voor AI-analyse gaat tekst naar de VS (Anthropic), onder wettelijke waarborgen, niet gebruikt voor AI-training, binnen 30 dagen verwijderd.

Hoe lang: we bewaren je input maximaal **[3] maanden** na de sessie.

Vrijwillig: deelname is vrijwillig. Je mag op elk moment stoppen of je toestemming intrekken — dan verwijderen we je input, zonder dat dit gevolgen heeft voor je **[vergoeding: €/cadeaubon]**.

Vragen of verwijderen: **[contact bij Klant]**.

☐ Ik geef toestemming voor het vastleggen en verwerken van mijn input zoals hierboven beschreven.

Naam: _____ Datum: _____ Handtekening: _____

Wiring into the platform (next step)

These are text; to make them true they must appear in the product:

Consent notice → render on the intake page (collapsible "Even over je privacy").

Panel consent → a gate on `/s/<token>/test/<cid>` (or a paper form the panel host collects, recorded by name).

Scope this as a small UI task — flagged in `09_open-items-and-decisions.md`.

Open items & decisions

The honest punch-list. Nothing here blocks a demo; several items block taking a real client's data. Grouped by when they must be done.

See `README.md` .

Before the first real client sprint (must-do)

#	Item	Why	Owner
1	Per-user facilitator logins (replace the shared password)	Accountability + audit + revocation; the #1 security gap	Build
2	Get the three DPAs on file — Anthropic (accept), Vercel (accept), Turso (request via trust portal)	Art. 28 requires them before processing	Founders
3	Verify Anthropic DPF status at <code>dataprivacyframework.gov/list</code>	Transfer assessment; sources conflict — don't state unconfirmed	Founders
4	Confirm SCC versions in all three DPAs; confirm Turso's transfer mechanism	The transfer story depends on it	Lawyer
5	Wire the privacy notices in (08_...) — crew notice on intake, panel consent on the test view	Art. 13 information duty + consent must actually be shown	Build
6	Legal review of the DPA + DPIA (03_... , 06_...)	They're binding/regulated instruments	Lawyer / DPO
7	Confirm panel consent + incentive process and recording	Lawful basis for the consumer panel	Panel host

Before scaling past the pilot (should-do)

#	Item	Why
8	MFA on facilitator accounts	Credential-compromise resistance
9	Access audit logging on facilitator routes	Show who accessed what
10	Schedule <code>npm run backup</code> (cron / Vercel Cron)	No missed backup before an incident
11	One-page incident-response runbook	Faster, consistent breach handling + the 24/48h clock
12	Client-link expiry / rotation	Bearer-token links shouldn't live forever

#	Item	Why
13	Light penetration test	Unknown unknowns

Strategic decision (only if a client requires it)

#	Decision	Trade-off
14	Move AI processing to the EU (Claude on AWS Bedrock EU / Vertex <code>region:"eu"</code>)	Removes the US transfer entirely; costs an architecture change (SDK/auth/model-id) + model-availability check. Decide only if a client makes EU AI residency a condition.
15	Pin Anthropic <code>inference_geo:"us"</code> as an interim	Makes the US transfer definite and documentable (vs. "global/anywhere") at ~1.1× cost; still US. Cheap middle option.

Already done (this pass)

- App compute pinned to **EU — Frankfurt** (`vercel.json`).
- Working **erasure** (`npm run delete-sprint`) and **backup** (`npm run backup`).
- Honest data-flow, subprocessor list, DPA template, retention policy, TOMs, DPIA input, security questionnaire, Dutch notices drafted.
- Confirmed no secrets in git; secrets via env only.